

C1 — Quản lý người dùng

Mô tả

Admin xem, tìm kiếm và kiểm soát toàn bộ tài khoản. Khi khoá bác sĩ có lịch hẹn đang hoạt động, hệ thống cảnh báo. Admin không thể tự khoá chính mình.

Đối tượng sử dụng

Người dùng	Vai trò
Admin	Xem, tìm kiếm, khoá/mở khoá tài khoản

Luồng nghiệp vụ

1. Xem danh sách người dùng (có phân trang)

- Admin vào `/admin/users`.
- Danh sách phân trang (20 user/trang), mặc định sắp theo ngày tạo mới nhất.
- Mỗi dòng: ảnh, họ tên, email, role, ngày đăng ký, trạng thái.

2. Tìm kiếm & lọc

- Tìm theo tên hoặc email.
- Lọc: role (Tất cả / Bệnh nhân / Bác sĩ), trạng thái (Tất cả / Active / Locked).

3. Khoá tài khoản bệnh nhân

- Admin nhấn "Khoá", bắt buộc nhập lý do.
- `users.status = 'locked'`.
- Gửi email thông báo kèm lý do.
- Ghi vào `audit_logs`.

4. Khoá tài khoản bác sĩ

- Admin nhấn "Khoá".
- Server kiểm tra bác sĩ còn lịch hẹn `pending` / `confirmed` không.
- Nếu có → **hiển thị cảnh báo**: "Bác sĩ này còn [N] lịch hẹn đang hoạt động. Nếu khoá, bạn cần xử lý các lịch đó." Hiển thị danh sách lịch hẹn ngăn.
- Admin xác nhận → `users.status = 'locked'`, ghi lý do.
- Lịch hẹn pending/confirmed của bác sĩ bị khoá cần được Admin xử lý thủ công** (hủy qua C5 hoặc liên hệ bệnh nhân). Hệ thống không tự hủy.

6. Ghi `audit_logs`.

5. Mở khoá

- 1. Admin nhấn "Mở khoá" → `users.status = 'active'`.
- 2. Ghi `audit_logs`.

Bảng dữ liệu liên quan

Bảng	Mục đích
<code>users</code>	Tài khoản và trạng thái
<code>appointments</code>	Kiểm tra lịch active khi khoá bác sĩ
<code>audit_logs</code>	Ghi lại mọi thao tác khoá/mở

API Endpoints

Method	Endpoint	Auth	Mô tả
GET	<code>/api/admin/users?page=1&role=doctor&status=active</code>		Danh sách có phân trang, lọc
GET	<code>/api/admin/users/:id</code>		Chi tiết tài khoản
PATCH	<code>/api/admin/users/:id/lock</code>		Khoá tài khoản (kèm lý do)
PATCH	<code>/api/admin/users/:id/unlock</code>		Mở khoá

Ràng buộc & Quy tắc nghiệp vụ

- Khoá **bắt buộc** nhập lý do.
- **Admin không thể khoá chính mình** — server check `req.user.id !== targetId` và cả `target.role !== 'admin'`.
- Khoá bác sĩ → cảnh báo nếu còn lịch hẹn active, nhưng Admin **quyết định có khoá không**.
- Tài khoản bị khoá sẽ không đăng nhập được. JWT cũ còn hạn vẫn hoạt động đến khi hết hạn (stateless JWT — thiết kế có chủ ý).
- Mọi thao tác ghi vào `audit_logs`.
- API có **phân trang** (20 user/trang).

Giao diện cần xây dựng

- Bảng danh sách có phân trang và bộ lọc
- Chi tiết tài khoản trong modal
- Dialog khoá: ô nhập lý do + cảnh báo lịch hẹn active (nếu là bác sĩ)
- Badge trạng thái: Xanh (active) / Đỏ (locked)

Chức năng liên quan

- **A1** — Dữ liệu tài khoản từ A1
- **C2** — Bác sĩ trong danh sách có thể xem hồ sơ chuyên môn
- **C5** — Sau khi khoá bác sĩ, Admin cần vào C5 để xử lý lịch hẹn còn lại